

THOMAZ KLIFSON FALCÃO BARBOZA

**CRIPTOAGILIDADE ORIENTADA POR CBOM PARA MIGRAÇÃO
PÓS-QUÂNTICA EM AMBIENTES HÍBRIDOS THREE-TIER**
Método e validação experimental em topologia bancária simulada

São Paulo
2026

THOMAZ KLIFSON FALCÃO BARBOZA

**CRIPTOAGILIDADE ORIENTADA POR CBOM PARA MIGRAÇÃO
PÓS-QUÂNTICA EM AMBIENTES HÍBRIDOS THREE-TIER**
Método e validação experimental em topologia bancária simulada

Trabalho de Conclusão de Curso
apresentado ao Instituto de Tecnologia e
Liderança - Inteli como requisito parcial
para obtenção do título de bacharel em
Ciência da Computação.

Orientador: Prof. Reginaldo Arakaki

São Paulo
2026

Catálogo em Publicação
Serviço de Biblioteca e Documentação
Instituto de Tecnologia e Liderança (INTELI)
Dados inseridos pelo autor.

BARBOZA, Thomaz Klifson Falcão. Criptoagilidade orientada por CBOM para migração pós-quântica em ambientes híbridos three-tier: método e validação experimental em topologia bancária simulada. 2026. 31 f. Trabalho de Conclusão de Curso (Graduação em Ciência da Computação) - Instituto de Tecnologia e Liderança, São Paulo, 2026.

RESUMO

A migração de criptografia de chave pública para algoritmos resistentes a adversários quânticos exige mais do que a substituição de primitivas. Em ambientes corporativos híbridos, dependências criptográficas aparecem em aplicações, protocolos, certificados, bibliotecas, bancos de dados, serviços de segredos e pipelines, o que dificulta inventário, priorização, implantação gradual e recuperação. Este trabalho propõe um roteiro de criptoagilidade orientado por Cryptography Bill of Materials (CBOM) para governar a migração em arquiteturas three-tier. O método combina inventário CBOM/SBOM, decisão por políticas, gateway de governança, implantação canária, observabilidade, critérios de rollback e retenção de evidências. A validação empregou uma topologia bancária simulada com oito nós lógicos em Podman rootless e cenários executados com k6. Nos testes nominais, S4-T01 concluiu 150 requisições sem falhas, com p95 de 39,71 ms, e S4-T02 concluiu 40 requisições sem falhas, com p95 de 24,70 ms. S4-T03 confirmou funcionalmente a cadeia aplicação, mock-vault, banco e nó canário por HTTP 200, sem comprovar mTLS. A comparação controlada S4-COMP manteve rota, carga, 5 usuários virtuais e 30 segundos, obtendo p95 de 42,58 ms no baseline e 27,20 ms no canário; esse resultado descreve diferenças operacionais, não overhead de criptografia pós-quântica. Sob stress, 10.000 requisições foram concluídas sem falhas HTTP, porém o p95 de 1149,64 ms violou o SLO LAT-01. Na indisponibilidade do mock-vault/KMS simulado, a aplicação retornou HTTP 500 e recuperou HTTP 200 após o reinício. As evidências indicam viabilidade do roteiro de governança e expõem limites relevantes: não foram comprovados mTLS real, KMS real ou algoritmos pós-quânticos no dataplane.

Palavras-chave: criptoagilidade; criptografia pós-quântica; CBOM; arquitetura three-tier; migração criptográfica.

ABSTRACT

Migrating public-key cryptography to algorithms designed to resist quantum adversaries requires more than replacing cryptographic primitives. In hybrid enterprise environments, cryptographic dependencies occur in applications, protocols, certificates, libraries, databases, secret services, and pipelines, making inventory, prioritization, gradual deployment, and recovery difficult. This work proposes a Cryptography Bill of Materials (CBOM)-driven crypto-agility roadmap for governing migration in three-tier architectures. The method combines CBOM/SBOM inventory, policy-driven decisions, a governance gateway, canary deployment, observability, rollback criteria, and evidence retention. Validation used a simulated banking topology with eight logical nodes running under rootless Podman and scenarios executed with k6. In nominal tests, S4-T01 completed 150 requests without failures and achieved a 39.71 ms p95, while S4-T02 completed 40 requests without failures and achieved a 24.70 ms p95. S4-T03 functionally confirmed the application, mock-vault, database, and canary chain through HTTP 200, without demonstrating mTLS. The controlled S4-COMP comparison kept the route, workload, five virtual users, and 30-second duration constant, obtaining p95 values of 42.58 ms for the baseline and 27.20 ms for the canary; this result describes operational differences, not post-quantum cryptography overhead. Under stress, 10,000 requests completed without HTTP failures, but the 1149.64 ms p95 violated the LAT-01 SLO. During simulated mock-vault/KMS unavailability, the application returned HTTP 500 and recovered to HTTP 200 after restart. The evidence indicates the feasibility of the governance roadmap while exposing relevant limits: real mTLS, a real KMS, and post-quantum algorithms in the dataplane were not demonstrated.

Key words: crypto-agility; post-quantum cryptography; CBOM; three-tier architecture; cryptographic migration.

LISTA DE TABELAS

Tabela 1 - Relação entre problema, objetivos e evidências

Tabela 2 - Comparação entre abordagens relacionadas

Tabela 3 - Nós lógicos da topologia experimental

Tabela 4 - Cenários e critérios de avaliação

Tabela 5 - Resultados experimentais consolidados

Tabela 6 - Comparação controlada entre baseline e cenário

Tabela 7 - Resultado do cenário de stress

Tabela 8 - Falha e recuperação do mock-vault/KMS simulado

Tabela 9 - Matriz do que foi e não foi comprovado

Tabela 10 - Ameaças à validade e medidas de mitigação

LISTA DE ABREVIATURAS E SIGLAS

API - Application Programming Interface

CBOM - Cryptography Bill of Materials

CNG - Cryptography API: Next Generation

CSP - Cryptographic Service Provider

FIPS - Federal Information Processing Standards

HMAC - Hash-based Message Authentication Code

HNDL - Harvest Now, Decrypt Later

HSM - Hardware Security Module

HTTP - Hypertext Transfer Protocol

JCA - Java Cryptography Architecture

KEM - Key-Encapsulation Mechanism

KMS - Key Management Service

mTLS - Mutual Transport Layer Security

NCCoE - National Cybersecurity Center of Excellence

NIST - National Institute of Standards and Technology

PQC - Post-Quantum Cryptography

SBOM - Software Bill of Materials

SLO - Service Level Objective

TLS - Transport Layer Security

VU - Virtual User

SUMÁRIO

1 INTRODUÇÃO.....	9
1.1 Contexto e motivação.....	9
1.2 Problema de pesquisa.....	9
1.3 Objetivo geral.....	9
1.4 Objetivos específicos.....	10
1.5 Justificativa.....	10
1.6 Escopo.....	10
1.7 Contribuições realizadas.....	12
2 FUNDAMENTAÇÃO TEÓRICA.....	13
2.1 Criptoagilidade.....	13
2.2 Criptografia pós-quântica.....	13
2.3 Risco harvest now, decrypt later.....	13
2.4 CBOM e SBOM.....	14
2.5 Ambientes híbridos three-tier.....	14
2.6 NIST, NCCoE e os padrões FIPS 203, 204 e 205.....	14
2.7 Provedores de serviços criptográficos.....	14
3 TRABALHOS RELACIONADOS.....	16
3.1 Microsoft CryptoAPI/CSP e CNG.....	16
3.2 Java Cryptography Architecture.....	16
3.3 PKCS #11 e HSMs.....	16
3.4 NIST/NCCoE Migration to Post-Quantum Cryptography.....	16
3.5 CycloneDX/CBOM.....	16
3.6 IBM/PQCA CBOMkit.....	16
3.7 Trabalhos acadêmicos.....	17
3.8 Síntese da novidade.....	18
4 METODOLOGIA.....	19
4.1 Tipo de pesquisa.....	19
4.2 Abordagem metodológica.....	19
4.3 Topologia experimental.....	19
4.4 Cenários S4.....	20
4.5 Métricas e critérios.....	21
4.6 Protocolo de reprodutibilidade.....	21
4.7 Ética e proteção de dados.....	22
5 ARQUITETURA E IMPLEMENTAÇÃO.....	23
5.1 Visão geral.....	23
5.2 Fluxo CBOM.....	23
5.3 Gateway e decisão por políticas.....	23
5.4 Implantação canária.....	23
5.5 Mock-vault/KMS simulado.....	23
5.6 Integridade de manifesto com HMAC-SHA256.....	24

5.7 Observabilidade, carga e caos.....	24
6 EXPERIMENTOS E RESULTADOS.....	25
6.1 Visão consolidada.....	25
6.2 S4-T01 baseline.....	25
6.3 S4-T02 canário.....	25
6.4 S4-T03 app-chain.....	26
6.5 S4-COMP baseline versus canário.....	26
6.6 S4-E03 stress.....	26
6.7 S4-E01 mock-vault/KMS simulado indisponível.....	27
6.8 S4-E04 integridade de manifesto.....	28
7 DISCUSSÃO.....	29
7.1 Interpretação dos resultados.....	29
7.2 O que foi comprovado.....	29
7.3 Prover primitivas versus governar migração.....	30
7.4 Comparação com trabalhos relacionados.....	30
7.5 Healthchecks e observabilidade.....	30
8 LIMITAÇÕES E AMEAÇAS À VALIDADE.....	31
8.1 Limitações.....	31
8.2 Ameaças à validade.....	31
9 CONCLUSÃO.....	33
REFERÊNCIAS.....	34
APÊNDICE A - EVIDÊNCIAS EXPERIMENTAIS.....	36
APÊNDICE B - COMANDOS DE REPRODUÇÃO.....	37
APÊNDICE C - ESTRUTURA DOS ARTEFATOS.....	38
APÊNDICE D - PENDÊNCIAS PARA VERSÃO FINAL.....	39

1 INTRODUÇÃO

1.1 Contexto e motivação

Criptografia de chave pública sustenta autenticação, estabelecimento de chaves, assinaturas digitais e proteção de comunicações em sistemas corporativos. A possibilidade de computadores quânticos criptograficamente relevantes comprometerem problemas matemáticos usados por RSA e criptografia de curvas elípticas amplia a necessidade de transição para algoritmos pós-quânticos. A urgência não depende apenas da data em que tal computador estará disponível. Dados capturados hoje podem permanecer sensíveis por anos e ser armazenados para decifração futura, caracterizando o risco *harvest now, decrypt later* (MOSCA, 2018; NCCOE, 2023).

O NIST publicou, em 13 de agosto de 2024, os primeiros padrões pós-quânticos: FIPS 203 para ML-KEM, FIPS 204 para ML-DSA e FIPS 205 para SLH-DSA (NIST, 2024a; 2024b; 2024c). A existência de padrões, contudo, não torna a migração automática. Uma organização precisa descobrir onde algoritmos e chaves são usados, entender dependências entre camadas, priorizar ativos, preparar compatibilidade e executar mudanças sem interromper serviços críticos. O NIST trata criptoagilidade como capacidade de substituir e adaptar algoritmos em protocolos, aplicações, software, hardware, firmware e infraestrutura, preservando segurança e continuidade operacional (BARKER et al., 2025).

Ambientes híbridos three-tier tornam esse problema particularmente distribuído. A camada web pode terminar TLS; a camada de aplicação pode usar bibliotecas, certificados e APIs; a camada de dados pode depender de criptografia em repouso, backup e serviços de segredos. Componentes on-premises, cloud e legados podem ter ciclos de atualização e responsáveis diferentes. Uma migração sem inventário e evidência pode corrigir um ponto e manter outros vulneráveis, ou introduzir incompatibilidade, regressão de latência e indisponibilidade.

1.2 Problema de pesquisa

O problema investigado é a ausência de um fluxo operacional integrado que conecte descoberta criptográfica, priorização por políticas, implantação incremental, observabilidade e recuperação em arquiteturas corporativas distribuídas.

Formula-se a seguinte pergunta de pesquisa:

Como um roteiro orientado por CBOM pode apoiar a governança e a validação incremental da migração criptográfica pós-quântica em um ambiente híbrido three-tier, preservando rastreabilidade e explicitando limites operacionais?

1.3 Objetivo geral

Desenvolver e validar experimentalmente um roteiro reproduzível de criptoagilidade orientado por CBOM para governar a migração criptográfica em ambientes híbridos three-tier.

1.4 Objetivos específicos

- 1 Sistematizar conceitos de criptoagilidade, criptografia pós-quântica, CBOM/SBOM e arquitetura three-tier.
- 2 Diferenciar provisão de primitivas criptográficas de governança de migração em sistemas distribuídos.
- 3 Definir um fluxo que conecte inventário, políticas, decisão, implantação canária, observabilidade e rollback.
- 4 Construir uma topologia bancária simulada com oito nós lógicos e dados sintéticos.
- 5 Executar cenários nominais, comparação controlada, stress, falha de dependência e integridade de manifesto.
- 6 Avaliar disponibilidade, latência, recuperação e rastreabilidade sem extrapolar o que os artefatos comprovam.

1.5 Justificativa

A contribuição prática decorre da dificuldade de transformar guias e padrões em um processo operacional verificável. Provedores criptográficos, bibliotecas e HSMs tornam primitivas e chaves acessíveis, mas não produzem automaticamente um inventário organizacional nem definem prioridades, canários, SLOs e rollback. CBOMs melhoram visibilidade, porém a representação do ativo não decide quando e como migrá-lo. O trabalho busca integrar esses elementos em um roteiro observável e reproduzível.

A contribuição acadêmica está na combinação e avaliação de componentes normalmente estudados de forma separada. Hasan et al. (2023) propõem análise de dependências para priorizar migração; Näther et al. (2024) mostram que a definição de criptoagilidade ainda possui variações; Cho et al. (2024) discutem governança centralizada por criptografia definida por software. Este estudo acrescenta uma validação local em topologia three-tier, incluindo comparação controlada, stress e indisponibilidade de dependência, com resultados negativos preservados na análise.

1.6 Escopo

O escopo inclui:

- inventário e representação de dependências por CBOM/SBOM;

- protótipo de gateway de decisão por políticas;
- implantação e validação canária simulada;
- topologia lógica de oito nós em Podman rootless;
- testes de carga com k6;
- falha e recuperação de mock-vault/KMS simulado;
- integridade de manifesto com HMAC-SHA256;
- retenção de logs, JSONs, saídas de comandos e resultados consolidados.

O escopo não inclui:

- implantação em produção ou cloud distribuída;
- mTLS real entre os nós;
- KMS ou HSM real;
- execução comprovada de ML-KEM, ML-DSA ou SLH-DSA no dataplane;
- medição de overhead criptográfico pós-quântico;
- rollback totalmente automatizado;
- análise de custo;

- entrevistas com especialistas ou pesquisa com participantes humanos.

1.7 Contribuições realizadas

As contribuições realizadas são:

- 1 um roteiro em cinco etapas: descobrir, decidir, migrar, validar e consolidar;
- 2 uma distinção técnica entre provedores de serviços criptográficos e governança de migração;
- 3 uma topologia reprodutível de oito nós com papéis de aplicação, dados, segurança, controle, observabilidade e carga;
- 4 uma campanha experimental revalidada, incluindo resultados favoráveis e violações de SLO;
- 5 um pacote de evidências que permite auditoria dos valores apresentados;
- 6 uma análise explícita do que foi e do que não foi comprovado.

Tabela 1 – Relação entre problema, objetivos e evidências

Elemento	Formulação	Evidência principal
Problema	Dependências distribuídas dificultam governança de migração	CBOM, topologia e cenários S4
Objetivo	Validar roteiro orientado por CBOM	gateway, canário e evidências
Desempenho nominal	Verificar operação sob carga nominal	S4-T01, S4-T02 e S4-T03
Comparabilidade	Controlar rota, carga e duração	S4-COMP
Resiliência	Observar stress e falha de dependência	S4-E03 e S4-E01
Integridade	Bloquear manifesto adulterado	S4-E04 complementar/local; servidor pendente

Fonte:** elaborada pelo autore (2026).

2 FUNDAMENTAÇÃO TEÓRICA

2.1 Criptoagilidade

Criptoagilidade é a capacidade de adaptar ou substituir mecanismos criptográficos sem provocar mudanças desproporcionais na aplicação ou interromper operações. O conceito abrange algoritmos, protocolos, bibliotecas, interfaces, hardware, firmware e processos de gestão. A revisão de Näther et al. (2024) identifica múltiplas dimensões nas definições existentes, como substituíbilidade, interoperabilidade e contexto organizacional. O NIST reforça que criptoagilidade não é apenas uma propriedade de código: ela exige coordenação entre arquitetos, desenvolvedores, operadores, gestores de risco e fornecedores (BARKER et al., 2025).

Uma arquitetura pode permitir troca de algoritmo por configuração e ainda não ser criptoágil em sentido organizacional. Se a organização desconhece quais serviços usam o algoritmo, não consegue medir compatibilidade ou não possui rollback, a substituição permanece arriscada. Neste trabalho, criptoagilidade é operacionalizada por inventário, decisão por políticas, implantação limitada, observação de SLOs e retenção de evidências.

2.2 Criptografia pós-quântica

Criptografia pós-quântica reúne algoritmos executáveis em computadores convencionais e projetados para resistir a ataques clássicos e quânticos conhecidos. O FIPS 203 especifica ML-KEM para estabelecimento de segredo compartilhado. O FIPS 204 especifica ML-DSA, uma família de assinaturas baseada em reticulados. O FIPS 205 especifica SLH-DSA, uma assinatura sem estado baseada em hash (NIST, 2024a; 2024b; 2024c).

Os padrões definem primitivas, parâmetros e operações. Eles não especificam, por si só, como uma organização deve localizar certificados RSA, substituir integrações de terceiros, atualizar protocolos, observar regressões ou coordenar múltiplos ambientes. O trabalho de Bos et al. (2018), relativo ao precursor de ML-KEM, ilustra que propriedades de segurança e desempenho da primitiva são um nível de análise distinto da governança de sua adoção.

2.3 Risco harvest now, decrypt later

O risco HNDL ocorre quando um adversário coleta tráfego cifrado hoje e o preserva até que avanços criptanalíticos ou computacionais permitam decifrá-lo. O modelo de Mosca (2018) relaciona o tempo de confidencialidade dos dados, o tempo necessário para migração e o horizonte da ameaça. Assim, ativos com longa vida de sigilo podem demandar ação antes da existência de um computador quântico capaz de quebrar os algoritmos atuais.

Esse risco também evidencia por que a migração precisa começar pelo inventário. Sem saber onde dados de longa duração são protegidos e quais algoritmos participam do estabelecimento de chaves, a organização não consegue priorizar adequadamente.

2.4 CBOM e SBOM

Um SBOM registra componentes de software e suas relações. Um CBOM complementa essa visão com algoritmos, protocolos, certificados, chaves, bibliotecas criptográficas, parâmetros e relações entre esses ativos. O CycloneDX oferece uma representação estruturada para ativos criptográficos e suas dependências, apoiando transparência e preparação para transição pós-quântica (OWASP CYCLONEDX, 2026).

O CBOMkit reúne geração de CBOM, visualização, armazenamento e verificação de conformidade. Sua documentação também reconhece limitações de cobertura estática, especialmente quando um projeto não é compilado antes da varredura (CBOMKIT PROJECT, 2026). Isso reforça que inventário automatizado deve ser validado e combinado com outras fontes, como configuração de runtime, certificados implantados e telemetria.

2.5 Ambientes híbridos three-tier

Arquiteturas three-tier separam apresentação, lógica de aplicação e persistência. Em um ambiente híbrido, cada camada pode estar distribuída entre infraestrutura local e cloud, com gateways, redes internas, serviços gerenciados e componentes legados. A criptografia atravessa essas fronteiras: TLS na entrada, autenticação e tokens na aplicação, conexões com banco, criptografia em repouso, backups e gestão de segredos.

A separação em camadas facilita responsabilidades, mas também cria dependências de ponta a ponta. Uma alteração no estabelecimento de chaves pode afetar cliente, proxy, serviço e biblioteca. A migração deve, portanto, observar a cadeia completa, e não apenas o componente onde a primitiva é implementada.

2.6 NIST, NCCoE e os padrões FIPS 203, 204 e 205

O projeto do NCCoE para migração pós-quântica enfatiza descoberta de criptografia de chave pública e testes de interoperabilidade (NCCOE, 2023a; 2023b). Esses materiais orientam organizações e apresentam arquiteturas de referência, mas precisam ser adaptados ao contexto local. O roteiro deste trabalho usa a descoberta como entrada, associa políticas e adiciona experimentos próprios de canário, carga e falha.

Os FIPS 203, 204 e 205 são tratados como estados-alvo normativos, não como evidência de implementação. Nenhum resultado experimental deste trabalho demonstra que essas primitivas foram executadas no dataplane.

2.7 Provedores de serviços criptográficos

Provedores criptográficos resolvem o acesso a implementações e a material criptográfico. No modelo legado do Windows, um Cryptographic Service Provider contém implementações de padrões e algoritmos e pode operar em software ou delegar a hardware. A própria Microsoft recomenda CNG como substituto extensível

e agnóstico em relação à criptografia para CryptoAPI/CSP (MICROSOFT, 2021; 2025).

A Java Cryptography Architecture usa classes de serviço e provedores conectáveis para assinatura, hash, certificados, cifragem, geração e gestão de chaves, números aleatórios e mecanismos de encapsulamento. A aplicação pode solicitar um serviço sem se vincular a uma implementação específica (ORACLE, 2025). PKCS #11 define uma interface para tokens criptográficos e é amplamente usado para acessar HSMs e smart cards (OASIS OPEN, 2023). HSMs podem proteger chaves e executar operações em módulos com requisitos específicos; o FIPS 140-3 trata requisitos de segurança para módulos criptográficos (NIST, 2019).

A abstração oferecida por essas tecnologias é relevante para criptoagilidade porque reduz acoplamento entre consumidores e implementações. Entretanto, prover primitivas não equivale a governar migração. Um CSP, uma JCA ou um HSM não descobre automaticamente todos os pontos de uso da organização, não classifica criticidade de negócio, não seleciona ondas de migração, não implanta canários entre serviços e não preserva, por si só, uma trilha integrada de decisão, SLO e recuperação.

3 TRABALHOS RELACIONADOS

3.1 Microsoft CryptoAPI/CSP e CNG

CryptoAPI/CSP é um concorrente indireto porque demonstra abstração de serviços criptográficos no sistema operacional. Sua limitação para o problema deste trabalho é o escopo: ele oferece operações e provedores, mas não um processo organizacional de inventário e migração distribuída. CNG melhora extensibilidade e gestão de chaves, porém continua sendo uma infraestrutura de execução criptográfica, não um ciclo completo de governança.

3.2 Java Cryptography Architecture

A JCA oferece independência de implementação, interoperabilidade entre provedores e extensibilidade de algoritmos (ORACLE, 2025). Essas propriedades podem reduzir custo de substituição dentro de uma aplicação Java. Contudo, a JCA não representa dependências entre serviços heterogêneos, certificados externos, proxies, bancos e ambientes cloud. Ela é uma peça potencial do dataplane, enquanto a proposta atua no plano de governança.

3.3 PKCS #11 e HSMs

PKCS #11 e HSMs protegem material criptográfico e padronizam operações sobre tokens. Eles são essenciais para custódia e execução confiável de chaves, mas não substituem CBOM, análise de risco ou validação canária. Neste trabalho, não houve HSM real; o mock-vault não deve ser confundido com um token PKCS #11 nem com módulo validado sob FIPS 140-3.

3.4 NIST/NCCoE Migration to Post-Quantum Cryptography

O NCCoE é a abordagem mais próxima em orientação de processo, pois relaciona descoberta, arquitetura e testes de padrões (NCCOE, 2023a; 2023b). A diferença é que um guia nacional não substitui a implementação local. A proposta deste trabalho materializa uma versão reduzida do ciclo em uma topologia three-tier e registra resultados específicos, inclusive violações.

3.5 CycloneDX/CBOM

CycloneDX fornece a linguagem de representação. Sua força é interoperabilidade e detalhamento dos ativos. Sua limitação é não executar a decisão nem o rollout. Um CBOM pode indicar RSA ou ECDH, mas não determina sozinho o risco de negócio, a sequência de migração ou a reação a um SLO violado.

3.6 IBM/PQCA CBOMkit

CBOMkit é concorrente direto na etapa de descoberta e análise. A ferramenta, originada em trabalho de inventário criptográfico da IBM e atualmente mantida como projeto aberto, gera, visualiza, armazena e avalia CBOMs, inclusive com políticas externas (IBM RESEARCH, 2022; CBOMKIT PROJECT, 2026). Ainda assim, seu

foco não cobre isoladamente toda a cadeia de gateway, canário, stress, falha de dependência e recuperação avaliada neste trabalho. A proposta utiliza a ideia de inventário e acrescenta um roteiro operacional.

3.7 Trabalhos acadêmicos

Hasan et al. (2023) estruturam migração por análise de dependências e estudos de caso, contribuindo para priorização. Näther et al. (2024) sistematizam definições de criptoagilidade e evidenciam a necessidade de precisão conceitual. Cho et al. (2024) propõem criptografia definida por software e governança centralizada. Esses trabalhos fundamentam a necessidade de abstração, inventário e política, mas não apresentam a mesma combinação experimental em topologia three-tier com os cenários S4 aqui executados.

Tabela 2 – Comparação entre abordagens relacionadas

Abordagem	Foco principal	Inventário CBOM	Decisão por políticas	Validação canária	Stress/falha	Recuperação/rollback	Limitação em relação à proposta
CryptoAPI /CSP e CNG	APIs, algoritmos e chaves no Windows	Não	Parcial, por configuração	Não	Não	Não	Não governa dependências distribuídas
JCA	Provedores e serviços criptográficos Java	Não	Parcial, por seleção de provedor	Não	Não	Não	Escopo da aplicação/runtime Java
PKCS #11/HSM	Token, custódia e operações protegidas	Não	Parcial	Não	Não	Parcial, para chaves	Não prioriza migração organizacional
NIST/NCCoE	Orientação, descoberta e interoperabilidade	Sim, como insumo	Orienta	Orienta testes	Parcial	Orienta	Não substitui implementação local
CycloneDX/CBOM	Representação de ativos criptográficos	Sim	Não	Não	Não	Não	Representa, mas não orquestra

CBOMkit	Descoberta, visualização e conformidade	Sim	Sim, limitada/extensível	Não	Não	Não	Não cobre todo o ciclo operacional
Literatura acadêmica	Modelos, dependências e conceitos	Variável	Variável	Raro	Variável	Variável	Evidência three-tier ainda limitada
Proposta	Governança integrada e evidência experimental	Sim	Sim	Sim	Sim	Parcial	Ambiente simulado e dataplane sem PQC

Fonte:** elaborada pelo autore com base em Microsoft (2021; 2025), Oracle (2025), OASIS Open (2023), NCCoE (2023a; 2023b), OWASP CycloneDX (2026), CBOMkit Project (2026), Hasan et al. (2023), Näther et al. (2024) e Cho et al. (2024).

3.8 Síntese da novidade

A novidade não está em criar uma nova primitiva ou substituir CSPs. Ela está em organizar uma camada superior que governa transições entre estados criptográficos distribuídos. Essa camada usa CBOM como fonte, políticas para priorizar, gateway para registrar decisão, canário para limitar impacto, SLOs para validar, evidências para auditoria e procedimentos de recuperação. A combinação aproxima recomendações normativas de um processo reproduzível e mensurável.

4 METODOLOGIA

4.1 Tipo de pesquisa

Trata-se de pesquisa aplicada e exploratória, conduzida como estudo de caso quantitativo em ambiente controlado. É aplicada porque produz e avalia um roteiro e protótipos; é exploratória porque investiga como integrar componentes de governança ainda pouco consolidados em uma topologia específica.

Documentos antigos do projeto previam entrevistas e ambiente cloud. Essas etapas não possuem evidência final no repositório e, portanto, não integram o método executado descrito nesta monografia.

4.2 Abordagem metodológica

O estudo foi organizado em seis etapas:

- 1 revisão de padrões, guias e literatura;
- 2 definição de requisitos e métricas;
- 3 modelagem da topologia de oito nós;
- 4 implementação dos protótipos de CBOM e gateway;
- 5 execução e revalidação dos cenários S4;
- 6 triangulação entre resumos JSON, logs, respostas HTTP e documentação.

A unidade de análise foi a cadeia three-tier e seus controles de governança durante operação nominal, comparação controlada, stress, falha de dependência e adulteração de manifesto.

4.3 Topologia experimental

O ambiente foi executado em servidor acadêmico Ubuntu 24.04.3 LTS, com 64 vCPUs, 125 GiB de RAM e Podman 4.9.3 em modo rootless. O uso de Podman sem daemon e sem privilégios elevados reduz dependência de acesso administrativo, mas também diferencia o ambiente de um cluster de produção (PODMAN PROJECT, 2026).

Tabela 3 – Nós lógicos da topologia experimental

Nó lógico	Papel	Camadas/redes principais
k8s-control	plano de controle e execução de protótipos	cluster e observabilidade

k8s-worker-1	entrada web e baseline	ingresso, cluster e observabilidade
k8s-worker-2	aplicação e cadeia /chain	cluster, dados, segurança e observabilidade
k8s-worker-3	réplica marcada como canário	ingresso, cluster, dados, segurança e observabilidade
data-node	PostgreSQL e eventos sintéticos	dados e observabilidade
security-integration-node	mock-vault/KMS simulado por HTTP	segurança e observabilidade
observability-node	Prometheus previsto para métricas	observabilidade
load-chaos-node	k6 e indução de falhas	ingresso e observabilidade

Fonte:** elaborada pelos autores a partir dos artefatos do projeto (2026).

4.4 Cenários S4

Tabela 4 – Cenários e critérios de avaliação

Cenário	Categoria	Configuração	Critério principal
S4-T01	nominal	baseline, 5 VUs, 30 s	0 falhas e LAT-01
S4-T02	nominal	canário, carga nominal curta	0 falhas e LAT-01
S4-T03	funcional	cadeia app, segurança, banco e canário	HTTP 200 e campos funcionais
S4-COMP	comparação	mesma rota, 5 VUs, 30 s, 150 requisições por nó	comparação descritiva
S4-E03	stress	/chain, 50 VUs, 10.000 iterações	disponibilidade e LAT-01
S4-E01	falha	parada e reinício do nó de segurança	detecção, tolerância e recuperação
S4-E04	integridade complementar/local	manifesto íntegro e adulterado	bloqueio no protótipo; reexecução de servidor pendente

Fonte:** elaborada pelos autores (2026).

4.5 Métricas e critérios

As métricas quantitativas foram:

- requisições e iterações concluídas;
- taxa de falha HTTP;
- latência média;
- percentil 95 de latência;
- latência máxima no stress;
- código HTTP antes, durante e depois da falha;
- contador de eventos no banco;
- resultado da verificação de integridade.

O SLO LAT-01 exige p95 inferior a 150 ms. Disponibilidade funcional significa conclusão da requisição com status HTTP de sucesso. Recuperação significa retorno a HTTP 200 após restauração da dependência. Esses critérios não medem resistência pós-quântica, pois não houve primitivas PQC no dataplane.

4.6 Protocolo de reprodutibilidade

As evidências revalidadas estão em `docs/revalidation/` e no pacote localizado na raiz do repositório, `revalidation-evidence-2026-06-10.tgz`. O protocolo exige:

- 1 registrar versões do host, Podman, imagens e k6;
- 2 validar a topologia antes da carga;
- 3 executar o script correspondente ao cenário;
- 4 preservar saída textual e resumo JSON;
- 5 registrar ações manuais de falha e recuperação;

- 6 comparar valores extraídos com a tabela publicada;
- 7 não alterar logs originais;
- 8 em estudos futuros, executar ao menos três repetições independentes e calcular dispersão e intervalos de confiança.

4.7 Ética e proteção de dados

Foram usados dados sintéticos e uma topologia simulada. Não foram tratados dados bancários reais nem conduzidas entrevistas. Assim, não houve coleta de dados pessoais de participantes. Uma implantação futura com dados ou especialistas deve ser submetida aos procedimentos éticos e institucionais aplicáveis.

5 ARQUITETURA E IMPLEMENTAÇÃO

5.1 Visão geral

A arquitetura separa dataplane e plano de governança. O dataplane simulado contém entrada web, aplicação, banco e integração de segurança. O plano de governança contém inventário, políticas, gateway, evidências e procedimentos de implantação. Essa separação evita afirmar que o gateway executa criptografia pós-quântica: ele organiza decisões sobre estados criptográficos.

5.2 Fluxo CBOM

O scanner produz manifestos com componentes e achados. O gateway ingere o CBOM, valida sua estrutura e integridade, classifica algoritmos segundo políticas e gera ações recomendadas. No protótipo avaliado, um manifesto com três componentes produziu dois achados de alto risco, duas violações e duas ações de migração.

O CBOM é uma representação observável, não uma fonte infalível. Achados estáticos podem ser incompletos, e configurações de runtime podem divergir do código. Por isso, o roteiro prevê correlação posterior com telemetria e inventário de implantação.

5.3 Gateway e decisão por políticas

O gateway prototípico representa seis responsabilidades conceituais: ingestão de CBOM, avaliação de política, orquestração, correlação de telemetria, rollback/caos e integração com governança. Na implementação disponível, as funções mais concretas são ingestão, classificação, recomendação e integridade de manifesto. Integrações com filas, GitOps, service mesh e SIEM permanecem como arquitetura proposta.

As políticas desacoplam a regra de migração do código de negócio. Elas podem declarar algoritmos proibidos, estados-alvo, criticidade e exceções. A decisão deve ser versionada e vinculada ao CBOM de entrada para permitir auditoria.

5.4 Implantação canária

O nó `k8s-worker-3` representa uma réplica canária. A validação canária reduz a população exposta antes de expandir uma mudança. Neste ambiente, a marcação de canário é operacional; não há evidência de que o nó execute uma pilha criptográfica pós-quântica diferente. S4-COMP compara os nós sob as mesmas condições, mas não mede overhead criptográfico.

5.5 Mock-vault/KMS simulado

O `security-integration-node` expõe por HTTP um perfil estático identificado como `mock-vault`. Ele permite testar encadeamento e indisponibilidade de uma dependência de segurança, mas não executa geração, rotação, envelopamento ou

custódia real de chaves. Por isso, o termo KMS é sempre acompanhado de “simulado”.

5.6 Integridade de manifesto com HMAC-SHA256

A evidência complementar/local S4-E04 revelou que a adulteração de um manifesto podia reduzir ações recomendadas sem bloquear a automação. O protótipo foi alterado para calcular HMAC-SHA256 sobre uma representação canônica do manifesto e verificar o valor antes do processamento. Um artefato inválido passa a produzir código de saída 1.

HMAC-SHA256 fornece autenticação simétrica se a chave permanecer protegida. A implementação usa chave de ambiente e amostras locais; não equivale a assinatura digital corporativa, PKI, HSM ou gestão completa de chaves. Os documentos do repositório confirmam a implementação e o teste local, mas ainda listam como pendente a reexecução final no servidor acadêmico.

5.7 Observabilidade, carga e caos

O k6 gera as cargas e registra métricas de HTTP. Logs de aplicação e contadores do banco complementam a observação. A pilha Prometheus/Grafana foi planejada, porém o observability-node apresentou falha em capturas de runtime e vários healthchecks apareceram como unhealthy, mesmo quando endpoints funcionais responderam. Assim, a observabilidade deve ser considerada parcial.

6 EXPERIMENTOS E RESULTADOS

6.1 Visão consolidada

A Tabela 5 consolida somente os seis cenários da revalidação principal contidos no pacote de 10 de junho de 2026. S4-E04 é apresentado separadamente na Seção 6.8 como evidência complementar/local de protótipo.

Tabela 5 – Resultados experimentais consolidados

Cenário	Evidência observada	Status
S4-T01	150 requisições e iterações; 0 falhas; média 30,36 ms; p95 39,71 ms	aprovado
S4-T02	40 requisições e iterações; 0 falhas; média 20,43 ms; p95 24,70 ms	aprovado
S4-T03	HTTP 200; 51,17 ms; mock-vault; banco OK; cadeia funcional	aprovado funcionalmente
S4-COMP	150 + 150 requisições; 0 falhas; p95 42,58 ms e 27,20 ms	aprovado como comparação operacional
S4-E03	10.000 requisições; 0 falhas; p95 1149,64 ms	disponibilidade aprovada; LAT-01 reprovado
S4-E01	HTTP 200, depois 500, depois 200	parcialmente aprovado

Fonte:** elaborada pelos autores a partir do pacote de evidências (2026).

6.2 S4-T01 baseline

S4-T01 executou 150 iterações e 150 requisições na rota `/chain`. Não foram registradas falhas HTTP. A latência média foi 30,36 ms e o p95 foi 39,71 ms, abaixo do limite LAT-01 de 150 ms. O cenário foi aprovado para a janela nominal observada.

6.3 S4-T02 canário

S4-T02 executou 40 iterações e 40 requisições no nó marcado como canário. Não houve falhas HTTP. A média foi 20,43 ms e o p95 foi 24,70 ms. O cenário foi aprovado, mas sua carga diferente impede comparação causal direta com S4-T01.

6.4 S4-T03 app-chain

A chamada percorreu aplicação, security-integration-node, banco e nó canário. A resposta foi HTTP 200 com `elapsed_ms = 51,17`, `security.secret_profile = mock-vault` e `database.ok = true`. O resultado comprova o encadeamento funcional. Não comprova mTLS, pois o código e os logs mostram acesso a `http://security-integration-node:8080/secret`.

6.5 S4-COMP baseline versus canário

S4-COMP foi criado para corrigir a limitação metodológica da comparação entre S4-T01 e S4-T02. Os dois nós receberam a mesma rota `/chain`, 5 VUs, duração de 30 segundos e 150 requisições.

Tabela 6 – Comparação controlada entre baseline e canário

Métrica	Baseline	Canário	Variação
VUs	5	5	-
Duração	30 s	30 s	-
Requisições	150	150	-
Falhas HTTP	0	0	-
Média	31,13 ms	19,87 ms	-36,19%
p95	42,58 ms	27,20 ms	-36,12%

Fonte:** elaborada pelos autores a partir dos resumos k6 (2026).

O canário apresentou latência menor nessa execução. Não se pode inferir que a diferença decorra de PQC ou mTLS, pois nenhuma dessas condições foi comprovada no dataplane. O resultado é uma comparação operacional entre duas instâncias da topologia simulada.

6.6 S4-E03 stress

O cenário executou 10.000 transações sintéticas na rota `/chain` com 50 VUs. Todas foram concluídas e não houve falha HTTP.

Tabela 7 – Resultado do cenário de stress

Métrica	Resultado
Requisições concluídas	10.000
Iterações	10.000

Falhas HTTP	0
Taxa de falha	0,00%
Média	203,47 ms
p95	1149,64 ms
Máxima	6235,52 ms
Disponibilidade funcional	aprovada
LAT-01, p95 < 150 ms	reprovado

Fonte:** elaborada pelos autores a partir de S4-E03-stress/k6-summary.json (2026).

A arquitetura manteve disponibilidade funcional sob carga comprimida, mas a cauda de latência degradou de forma significativa. O p95 ficou aproximadamente 7,66 vezes acima do limite de 150 ms. O resultado identifica um gargalo ou contenção não localizado pela instrumentação disponível.

6.7 S4-E01 mock-vault/KMS simulado indisponível

Tabela 8 – Falha e recuperação do mock-vault/KMS simulado

Fase	Estado do serviço	HTTP	Latência cliente	Evidência
Antes	disponível	200	40,09 ms	mock-vault, banco OK, event_count=11500
Durante	nó parado	500	18,21 ms	<urlopen error [Errno -2] Name or service not known>
Depois	nó reiniciado	200	36,25 ms	mock-vault, banco OK, event_count=11501

Fonte:** elaborada pelos autores a partir das três capturas de S4-E01 (2026).

O cenário foi aprovado em detecção e recuperação após reinício, mas reprovado em tolerância sem erro HTTP. A aplicação não manteve resposta bem-sucedida durante a indisponibilidade. A menor latência da resposta 500 não representa melhoria; a cadeia falhou antes de completar suas dependências.

6.8 S4-E04 integridade de manifesto

O primeiro teste de adulteração revelou que a remoção de um achado reduzia de duas para uma as ações recomendadas, sem bloqueio. Após a inclusão de HMAC-SHA256, um manifesto com assinatura inválida passou a ser rejeitado antes da automação. A implementação e as amostras estão no repositório e o teste local foi documentado. S4-E04 não integra a revalidação principal de 10 de junho de 2026 nem o respectivo pacote de evidências. A checklist do projeto ainda registra como pendente a reexecução final no servidor e a cópia do log para o diretório de evidências. Portanto, a conclusão é limitada ao protótipo local.

7 DISCUSSÃO

7.1 Interpretação dos resultados

Os cenários nominais indicam que a topologia consegue executar a cadeia funcional com baixa latência nas janelas avaliadas. S4-COMP melhora a validade descritiva ao controlar rota, duração, concorrência e tamanho da amostra. Ainda assim, uma única execução não permite atribuir causalidade ao rótulo canário.

S4-E03 demonstra que disponibilidade e desempenho são dimensões diferentes. A taxa de erro de 0% não impediu a violação de LAT-01. Para sistemas bancários sensíveis à cauda de latência, esse resultado é material e impede concluir que a configuração está pronta para produção.

S4-E01 mostra detecção e recuperação simples, mas não tolerância plena. A propagação de HTTP 500 sugere ausência de cache seguro, redundância, circuit breaker com resposta degradada ou outra estratégia compatível com o requisito de negócio. Qualquer fallback para uma dependência de segurança deve ser analisado cuidadosamente para não reduzir controles.

7.2 O que foi comprovado

Tabela 9 – Matriz do que foi e não foi comprovado

Afirmação	Situação	Base
A topologia responde em baseline e canário nominal	comprovado nas janelas	S4-T01 e S4-T02
A cadeia app, mock-vault, banco e canário funciona	comprovado por HTTP	S4-T03
Baseline e canário podem ser comparados sob carga igual	comprovado descritivamente	S4-COMP
10.000 requisições terminam sem falha HTTP	comprovado	S4-E03
LAT-01 é violado sob stress	comprovado	S4-E03
A falha do mock-vault produz erro e a reinicialização recupera	comprovado	S4-E01
HMAC pode bloquear a amostra adulterada	evidência complementar/local; servidor pendente	S4-E04

Fonte:** elaborada pelos autores (2026).

Não foram comprovados mTLS real, KMS real, HSM, PQC no dataplane, overhead de PQC/mTLS, alta disponibilidade durante falha, rollback automatizado, observabilidade completa ou prontidão para produção.

7.3 Prover primitivas versus governar migração

CSP, CNG, JCA e PKCS #11 criam interfaces estáveis para solicitar operações e escolher implementações. HSMs acrescentam proteção física e lógica para chaves e operações. Esses mecanismos podem ser usados pela arquitetura alvo e facilitam substituição dentro de um contexto técnico.

Governar migração exige outra escala de decisão. É necessário descobrir consumidores, correlacionar dependências, classificar dados e serviços, definir política, selecionar ondas, validar manifesto, executar canário, observar SLO, interromper expansão, registrar evidência e recuperar o estado. A proposta se inspira no desacoplamento dos provedores, mas posiciona-se acima deles. Ela pode decidir que um serviço deve migrar e acompanhar a mudança; a execução da primitiva continuaria a cargo de uma biblioteca, provedor, token ou serviço criptográfico.

Essa distinção fortalece a novidade ao evitar uma reivindicação incorreta de CSP completo. O trabalho integra componentes existentes em um ciclo de governança e oferece evidência experimental local. A contribuição é arquitetural e metodológica, não algorítmica.

7.4 Comparação com trabalhos relacionados

NIST/NCCoE fornece amplitude normativa e arquitetural superior, mas não produz automaticamente evidência para uma organização específica. CycloneDX e CBOMkit oferecem inventário mais maduro que o protótipo local, porém não substituem o processo de canário, stress e recuperação. Hasan et al. (2023) oferecem análise de dependências mais formal; Cho et al. (2024) aprofundam governança definida por software. A proposta contribui ao reunir esses elementos em uma campanha reprodutível e ao publicar resultados que contrariam uma narrativa apenas positiva.

7.5 Healthchecks e observabilidade

Os healthchecks inconsistentes são uma limitação operacional. Endpoints funcionais responderam mesmo quando o runtime marcou containers como `unhealthy`. Isso pode decorrer da definição do healthcheck, do provider Compose ou da sequência de inicialização. Não se deve ignorar a divergência: em produção, healthchecks incorretos podem causar reinícios, remoção indevida de tráfego ou mascarar falhas. A pilha Prometheus/Grafana precisa ser corrigida antes de novas conclusões sobre causas de latência.

8 LIMITAÇÕES E AMEAÇAS À VALIDADE

8.1 Limitações

- 1 O ambiente é simulado e executado em um único servidor acadêmico.
- 2 Podman rootless não reproduz todos os comportamentos de Kubernetes ou cloud corporativa.
- 3 O mock-vault não é KMS real e não usa HSM.
- 4 S4-T03 usa HTTP e não comprova mTLS.
- 5 Não há ML-KEM, ML-DSA ou SLH-DSA comprovados no dataplane.
- 6 S4-COMP não mede overhead de PQC ou mTLS.
- 7 S4-E03 violou LAT-01.
- 8 S4-E01 retornou HTTP 500 durante a falha.
- 9 Os healthchecks e a observabilidade são inconsistentes.
- 10 A maioria dos cenários teve uma execução revalidada, sem análise estatística.
- 11 S4-E04 possui prova local, mas não a reexecução final de servidor listada na checklist.
- 12 Rollback automatizado, custo, rotação real e certificado expirado permanecem pendentes.

8.2 Ameaças à validade

Tabela 10 – Ameaças à validade e medidas de mitigação

Tipo	Ameaça	Mitigação aplicada ou futura
Construção	latência HTTP não mede segurança PQC	separar métricas operacionais de alegações criptográficas
Construção	nomes históricos sugerem mTLS/KMS	interpretar protocolo e código observados
Interna	host compartilhado, cache e escalonamento	registrar ambiente; repetir e randomizar no futuro

Interna	falha S4-E01 induzida manualmente	preservar timestamps e comandos
Conclusão	execução única e sem intervalo de confiança	limitar análise a estatística descritiva
Externa	oito containers não representam banco real	não extrapolar para produção
Externa	ausência de cloud, HSM e service mesh	ampliar ambiente em trabalhos futuros
Reprodutibilidade	imagens latest podem mudar	fixar digests e versões na próxima campanha

Fonte:** elaborada pelos autores (2026).

9 CONCLUSÃO

Este trabalho desenvolveu um roteiro prático de criptoagilidade orientado por CBOM para ambientes híbridos three-tier. A proposta conecta descoberta, decisão por políticas, implantação canária, observabilidade, recuperação e retenção de evidências. Sua principal contribuição é tratar migração criptográfica como um problema de governança distribuída, e não apenas como substituição de algoritmo ou uso de um provedor criptográfico.

A revalidação fortaleceu a base empírica. Baseline e canário operaram sem falhas HTTP nas janelas nominais; a cadeia de aplicação funcionou; S4-COMP estabeleceu uma comparação operacional controlada; S4-E03 concluiu 10.000 requisições; e S4-E01 registrou falha e recuperação do mock-vault. Os mesmos experimentos também delimitam a proposta: o stress violou LAT-01, a falha produziu HTTP 500 e a observabilidade permaneceu incompleta.

Não se pode concluir que a arquitetura implementa mTLS real, KMS real ou PQC no dataplane. Também não se pode atribuir as diferenças de S4-COMP a efeitos criptográficos. Essas limitações são centrais para a interpretação correta.

Como trabalhos futuros, recomenda-se:

- 1 implantar mTLS real e registrar negociação e certificados;
- 2 integrar KMS/HSM realista por PKCS #11 ou API equivalente;
- 3 executar ML-KEM, ML-DSA e/ou SLH-DSA no dataplane;
- 4 medir overhead criptográfico com baseline controlado e repetições;
- 5 automatizar rollback e testar sua efetividade;
- 6 corrigir Prometheus/Grafana e healthchecks;
- 7 investigar filas, conexões e recursos que explicam a cauda de S4-E03;
- 8 fixar versões e digests das imagens;
- 9 repetir experimentos com análise estatística;
- 10 avaliar uma infraestrutura cloud ou produção simulada mais robusta.

REFERÊNCIAS

- BARKER, Elaine et al. **Considerations for Achieving Crypto Agility: Strategies and Practices**. Gaithersburg: National Institute of Standards and Technology, 2025. NIST CSWP 39. DOI: 10.6028/NIST.CSWP.39.
- BOS, Joppe et al. CRYSTALS-Kyber: a CCA-secure module-lattice-based KEM. In: **IEEE European Symposium on Security and Privacy**, 2018. p. 353-367. DOI: 10.1109/EuroSP.2018.00032.
- CBOMKIT PROJECT. **CBOMkit: the essentials for Cryptography Bills of Materials**. 2026. Disponível em: <https://github.com/cbomkit/cbomkit>. Acesso em: 11 jun. 2026.
- CHO, Jihoon et al. **Software-Defined Cryptography: A Design Feature of Cryptographic Agility**. arXiv:2404.01808, 2024. Disponível em: <https://arxiv.org/abs/2404.01808>. Acesso em: 11 jun. 2026.
- HASAN, Khondokar Fida et al. **A Framework for Migrating to Post-Quantum Cryptography: Security Dependency Analysis and Case Studies**. arXiv:2307.06520, 2023. Disponível em: <https://arxiv.org/abs/2307.06520>. Acesso em: 11 jun. 2026.
- IBM RESEARCH. **Cryptographic Bill of Materials Speeds Quantum-Safe Adoption**. 2022. Disponível em: <https://research.ibm.com/blog/cryptographic-bill-of-materials>. Acesso em: 11 jun. 2026.
- MICROSOFT. **Cryptographic Service Providers**. 2021. Disponível em: <https://learn.microsoft.com/en-us/windows/win32/seccrypto/cryptographic-service-providers>. Acesso em: 11 jun. 2026.
- MICROSOFT. **Cryptography API: Next Generation**. 2025. Disponível em: <https://learn.microsoft.com/en-us/windows/win32/seccng/cng-portal>. Acesso em: 11 jun. 2026.
- MOSCA, Michele. Cybersecurity in an era with quantum computers: will we be ready? **IEEE Security & Privacy**, v. 16, n. 5, p. 38-41, 2018. DOI: 10.1109/MSP.2018.3761723.
- NÄTHER, Christian et al. **Toward a Common Understanding of Cryptographic Agility: A Systematic Review**. arXiv:2411.08781, 2024. Disponível em: <https://arxiv.org/abs/2411.08781>. Acesso em: 11 jun. 2026.
- NATIONAL CYBERSECURITY CENTER OF EXCELLENCE - NCCOE. **Migration to Post-Quantum Cryptography: Quantum Readiness: Cryptographic Discovery**. NIST SP 1800-38B, versão preliminar. Gaithersburg: NIST, 2023a.
- NATIONAL CYBERSECURITY CENTER OF EXCELLENCE - NCCOE. **Migration to Post-Quantum Cryptography: Quantum Readiness: Testing Draft Standards**. NIST SP 1800-38C, versão preliminar. Gaithersburg: NIST, 2023b.
- NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY - NIST. **FIPS 140-3: Security Requirements for Cryptographic Modules**. Gaithersburg: NIST, 2019. DOI: 10.6028/NIST.FIPS.140-3.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY - NIST. **FIPS 203: Module-Lattice-Based Key-Encapsulation Mechanism Standard**. Gaithersburg: NIST, 2024a. DOI: 10.6028/NIST.FIPS.203.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY - NIST. **FIPS 204: Module-Lattice-Based Digital Signature Standard**. Gaithersburg: NIST, 2024b. DOI: 10.6028/NIST.FIPS.204.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY - NIST. **FIPS 205: Stateless Hash-Based Digital Signature Standard**. Gaithersburg: NIST, 2024c. DOI: 10.6028/NIST.FIPS.205.

OASIS OPEN. **PKCS #11 Cryptographic Token Interface Base Specification Version 3.1**. 2023. Disponível em: <https://docs.oasis-open.org/pkcs11/pkcs11-base/v3.1/os/pkcs11-base-v3.1-os.html>. Acesso em: 11 jun. 2026.

ORACLE. **Java Cryptography Architecture (JCA) Reference Guide**. Java SE 25, 2025. Disponível em: <https://docs.oracle.com/en/java/javase/25/security/java-cryptography-architecture-jca-reference-guide.html>. Acesso em: 11 jun. 2026.

OWASP CYCLONEDX. **Cryptography Bill of Materials (CBOM)**. 2026. Disponível em: <https://cyclonedx.org/capabilities/cbom/>. Acesso em: 11 jun. 2026.

PODMAN PROJECT. **Podman Documentation**. 2026. Disponível em: <https://podman.io/docs>. Acesso em: 11 jun. 2026.

APÊNDICE A - EVIDÊNCIAS EXPERIMENTAIS

O pacote principal é `revalidation-evidence-2026-06-10.tgz`, localizado na raiz do repositório. Após extração, a pasta `revalidation/` contém:

- `summary-results.md`;
- resumos e saídas k6 de S4-T01 e S4-T02;
- resposta `app-chain.json` de S4-T03;
- resumos e comparação de S4-COMP;
- resumo, saída e relatório de S4-E03;
- capturas antes, durante e depois de S4-E01;
- capturas de runtime.

Uma cópia organizada também está em `docs/revalidation/`.

APÊNDICE B - COMANDOS DE REPRODUÇÃO

```
# Validar a composição
podman compose -f lab/topology/docker-compose.yml config

# Construir e iniciar
podman compose -f lab/topology/docker-compose.yml up -d --build

# Verificar os nós
podman compose -f lab/topology/docker-compose.yml ps

# Executar cenários por meio do controlador do laboratório
lab/topology/scripts/labctl.sh s4-t01
lab/topology/scripts/labctl.sh s4-t02
lab/topology/scripts/labctl.sh s4-e04

# Exemplo de stress
k6 run lab/topology/k6/stress-10000.js
```

Os comandos exatos de revalidação no servidor devem ser conferidos com os scripts e os caminhos de ambiente antes de nova execução.

APÊNDICE C - ESTRUTURA DOS ARTEFATOS

- code/
 - cbom_gateway.py
 - cbomkit_cli.py
- samples/
 - lab/topology/
 - docker-compose.yml
 - k6/
 - scripts/
- docs/module14/
- docs/module16/
- docs/revalidation/
 - revalidation-evidence-2026-06-10.tgz
- paper/
- tcc/

APÊNDICE D - PENDÊNCIAS PARA VERSÃO FINAL

- 1 Confirmar nome completo, ordem e papel de todos os autores.
- 2 Confirmar curso, orientador, coorientador e membros da banca.
- 3 Solicitar ficha catalográfica e folha de aprovação.
- 4 Decidir se haverá agradecimentos.
- 5 Atualizar sumário e lista de tabelas no Word após paginação final.
- 6 Validar se o nome institucional deve ser “Inteli - Instituto de Tecnologia e Liderança” ou outra forma oficial na capa.
- 7 Reexecutar S4-E04 no servidor e arquivar o log final, caso o cenário seja apresentado como evidência de servidor.
- 8 Revisar referências conforme a edição ABNT adotada pelo Inteli e validar referências em preprint.